

Agentic Mesh Risk & Controls Framework

Gateway Registry Pattern • Four Production Guardrails • Standards & Regulatory Alignment

Purpose	A practical risk-and-controls framework for operating agentic AI through a Gateway Registry. It is deliberately structured like a traditional risk/control matrix: each summary item identifies the risk, explains the exposure, defines the control objective and activities, and maps the control to established governance and risk frameworks.
Control plane	Gateway Registry + Policy-as-Code sits between agents and MCP servers. The gateway authenticates the agent, makes context-aware authorization decisions, records evidence, and maintains runtime provenance.
Four guardrails	1. Identity • 2. RBAC • 3. Audit & Evidence • 4. SPDX / AgBOM Provenance. Governance and policy-as-code are cross-cutting capabilities implemented through the gateway.

Executive view

Guardrail	Core risk	Primary control outcome
1 • Identity	The actor cannot be reliably attributed.	Every consequential invocation carries a cryptographically verifiable agent identity and version context.
2 • RBAC	Static credentials and permissions outlive the context that justified them.	Access is dynamic, scoped, time-bound, and enforced at the gateway.
3 • Audit & Evidence	Logs are incomplete, mutable, or disconnected from the exact agent state.	Each consequential action produces attestable, version-bound evidence that can be independently verified.
4 • SPDX / AgBOM	Build-time SBOMs do not describe a self-modifying agent at runtime.	Runtime composition is represented through an AgBOM and linked to the action/evidence record.

Important: This is a control-alignment framework, not a legal opinion or a claim of regulatory compliance. Regulatory applicability depends on the organization, jurisdiction, role in the AI supply chain, data, and use case.

1. Framework structure

The matrix uses the same basic logic as the KPMG AI Risk and Controls Matrix: a concise **Summary item** maps to a **risk**, a detailed **risk description**, a **control objective**, concrete **control activities**, and one or more external framework references. KPMG's matrix organizes AI risks into governance/control subjects and links controls to COBIT processes; this framework adapts that pattern to the Gateway Registry and agentic-mesh operating model.

Control hierarchy

Layer	Question answered	Example
Summary item	What can go wrong?	Agent is not attributable
Risk description	Why does it matter?	Shared service accounts break non-repudiation
Control objective	What must be true?	Every action has a verifiable principal
Control activities	How is it enforced?	SPIFFE/OAuth assertion at gateway; reject unsigned calls
Framework mapping	Which established framework does it support?	COBIT DSS05.04; NIST CSF Protect; NIST AI RMF Govern/Manage
Evidence	How can an auditor test it?	Signed identity assertion + gateway decision + timestamp

Frameworks used in this draft

COBIT 2019 is the primary enterprise governance/control taxonomy; **NIST CSF 2.0** provides the cybersecurity lifecycle; **NIST AI RMF 1.0** provides AI risk functions; **ISO/IEC 27001** and **ISO/IEC 42001** provide information-security and AI-management-system anchors. EU-oriented mappings include **EU AI Act**, **DORA**, **GDPR** and **CRA** where the control has a meaningful relationship. SOX is treated as a financial-reporting control overlay rather than an AI framework.

The mappings are intentionally outcome-oriented. A mapping means the Gateway control can support the relevant objective/control environment; it does not mean that implementing the Gateway alone satisfies the framework or law.

2. Summary risk & controls matrix

The following summary is designed to be the front-door risk register. The detailed records that follow can be used as control statements, test procedures, or inputs to a GRC system.

ID	Guardrail	Summary item	Primary risk	Primary control outcome
I-01	Identity	Agent not attributable	Agent identity cannot be reliably attributed	Every consequential call has a verifiable principal.
I-02	Identity	Runtime boundary unknown	Agent version and operating boundary are unknown	Identity includes version and policy context.
I-03	Identity	Delegation obscures origin	Delegation obscures the true initiating principal	Delegation is explicit, bounded, and traceable.
I-04	Identity	Stale/orphaned identities	Identity lifecycle is not synchronized with the registry	Identity lifecycle is centrally governed.
R-01	RBAC	Static permissions persist	Static permissions outlive the context that justified them	Access is dynamic, scoped, and time-bound.
R-02	RBAC	High-impact action bypasses approval	High-impact actions bypass human or second-factor approval	Sensitive actions trigger step-up/human approval.
R-03	RBAC	Runtime state ignored	Authorization ignores runtime agent state	Policy evaluates material runtime context.
R-04	RBAC	Policy changes are uncontrolled	Policy-as-code changes are not governed	Policy-as-code is versioned and change-controlled.
A-01	Audit & Evidence	Logs cannot prove what happened	Logs cannot prove exactly what happened	Structured evidence reconstructs consequential actions.
A-02	Audit & Evidence	Evidence can be altered	Evidence is mutable or cannot be independently verified	Evidence is tamper-evident and verifiable.
A-03	Audit & Evidence	Evidence lacks provenance/policy linkage	Audit evidence is disconnected from policy and provenance	Action, policy, identity and AgBOM are linked.
A-04	Audit & Evidence	Anomalies go undetected	Monitoring does not detect anomalous agent behavior	Evidence feeds detection and response.
P-01	SPDX / AgBOM	Static SBOM is stale	Build-time SBOM is treated as a complete runtime description	Runtime composition is represented by AgBOM/attestation.
P-02	SPDX / AgBOM	Provenance not tied to action	Agent provenance cannot be tied to the action	Action references exact runtime attestation.
P-03	SPDX / AgBOM	Composition changes bypass governance	Model, prompt, tool, or retrieval changes escape governance	Material changes trigger re-attestation/policy.
P-04	SPDX / AgBOM	Supply-chain evidence incomplete	Software and AI supply-chain evidence is incomplete	Components are inventoried and traceable.

3. Detailed control records — Identity

Agents are principals, not scripts. Identity establishes who is asking, what version is operating, and what delegation context is in force.

I-01 — Agent identity cannot be reliably attributed

Summary item	Agent not attributable
Risk description	Shared service accounts, API keys, or unsigned requests make it difficult to establish which agent instance initiated a consequential action. This weakens non-repudiation, incident response, access review, and accountability.
Control objective	Every consequential invocation is bound to a cryptographically verifiable agent principal.
Control activities	• Require a signed SPIFFE/SPIRE, OAuth 2.1, mTLS/x.509, or equivalent identity assertion at the gateway. • Bind the assertion to an agent identifier, agent/version identifier, issuance/expiry time, and relevant policy context. • Reject calls that lack a valid identity assertion or whose assertion is expired/revoked.
Framework mapping	COBIT DSS05.04; APO13; NIST CSF Govern/Protect; NIST AI RMF Govern/Manage; ISO/IEC 27001 access control; ISO/IEC 42001 AI governance
Audit evidence	Signed identity assertion; certificate/token validation result; gateway decision; revocation record

I-02 — Agent version and operating boundary are unknown

Summary item	Runtime boundary unknown
Risk description	An identity that says only 'agent-123' does not establish which model, prompt/policy bundle, or delegated boundary was active. Two materially different agent instances can appear identical to downstream systems.
Control objective	The identity context is sufficient to distinguish the actor and its authorized operating boundary.
Control activities	• Include agent release/version and policy version/hash in the invocation context. • Bind identity to the runtime AgBOM/evidence identifier where available. • Record changes in agent identity/version and require re-attestation after material changes.
Framework mapping	COBIT BAI10; MEA02/MEA04; NIST AI RMF Map/Measure; ISO/IEC 42001 traceability; DORA change/risk controls
Audit evidence	Agent registry record; version metadata; policy hash; change/attestation history

I-03 — Delegation obscures the true initiating principal

Summary item	Delegation obscures origin
Risk description	An agent may call another agent or service on behalf of a human or upstream agent. Without explicit delegation chains, the downstream system cannot determine who originated the action or whether delegation was authorized.
Control objective	Delegation is explicit, bounded, and traceable back to the originating principal.
Control activities	• Carry a signed delegation chain or equivalent provenance context. • Limit delegation depth and scope. • Require step-up/human approval for high-impact actions or privilege escalation.
Framework mapping	COBIT DSS05.04; APO12; NIST AI RMF Map/Manage; NIST CSF Protect; ISO/IEC 42001 human oversight
Audit evidence	Delegation chain; depth limit decision; approval evidence; final gateway decision

I-04 — Identity lifecycle is not synchronized with the registry

Summary item	Stale/orphaned identities
Risk description	Stale identities, expired credentials, or orphaned agents can retain access after retirement, incident response, role changes, or vendor termination.
Control objective	Agent identity has a controlled lifecycle from registration through suspension and retirement.
Control activities	• Maintain authoritative agent registration and ownership. • Automatically expire or revoke credentials when lifecycle conditions are met. • Reconcile active sessions and identities against the registry on a defined cadence.
Framework mapping	COBIT DSS05.04; APO13; MEA03; NIST CSF Govern/Protect; ISO/IEC 27001 identity lifecycle
Audit evidence	Registry status; revocation events; reconciliation reports; orphan-account exceptions

3. Detailed control records — RBAC

Permissions must be dynamic, scoped, and time-bound. The Gateway is the policy enforcement point between agent and tool.

R-01 — Static permissions outlive the context that justified them

Summary item	Static permissions persist
Risk description	Long-lived API keys and broad role grants allow an autonomous agent to retain access beyond the task, time window, or business purpose for which access was approved.
Control objective	Authorization is dynamic, scoped, and time-bound.
Control activities	• Evaluate role, resource, action, purpose, environment, and time at the gateway. • Issue just-in-time authorization for the minimum required scope. • Expire grants automatically and deny by default when context is missing.
Framework mapping	COBIT DSS05.04; APO12; NIST CSF Protect; NIST AI RMF Govern/Manage; ISO/IEC 27001 least privilege; DORA access controls
Audit evidence	Policy decision record; grant/expiry timestamps; denied-call record; access review

R-02 — High-impact actions bypass human or second-factor approval

Summary item	High-impact action bypasses approval
Risk description	An agent that can read market data may also be able to initiate a trade or other consequential transaction if permissions are not separated by action and impact.
Control objective	High-impact operations require explicit policy conditions and, where required, human approval or step-up authentication.
Control activities	• Classify tools/actions by impact. • Route sensitive actions to step-up approval rather than automatic execution. • Record the approver, decision, time, and policy version in the evidence record.
Framework mapping	COBIT DSS06; DSS05.04; NIST AI RMF Map/Manage; NIST CSF Protect; ISO/IEC 42001 human oversight; EU AI Act human oversight relevance; DORA ICT controls
Audit evidence	Approval record; policy decision; action classification; approver identity

R-03 — Authorization ignores runtime agent state

Summary item	Runtime state ignored
Risk description	A policy based only on a static role cannot account for changed model, prompt, retrieval sources, delegation depth, harm velocity, or other runtime conditions.
Control objective	Authorization decisions evaluate material runtime context in addition to the nominal role.
Control activities	• Make AgBOM/evidence status, delegation depth, environment, and other risk signals available to policy. • Version policies and record the exact policy version/hash used for every decision. • Fail closed when required context is unavailable or stale.
Framework mapping	COBIT APO12; BAI10; DSS05; NIST AI RMF Map/Measure/Manage; ISO/IEC 42001 risk treatment
Audit evidence	Policy input snapshot; policy hash; decision trace; stale-context rejection

R-04 — Policy-as-code changes are not governed

Summary item	Policy changes are uncontrolled
Risk description	A gateway can become a high-risk control point if policy changes are made without approval, testing, versioning, separation of duties, or rollback.
Control objective	Policy is treated as a controlled production asset with traceable change management.
Control activities	• Version policy-as-code in source control. • Require peer review, automated tests, approval, deployment controls, and rollback. • Record policy version/hash in the call evidence.
Framework mapping	COBIT BAI06; BAI10; MEA02; NIST CSF Govern/Protect; ISO/IEC 27001 change control; ISO/IEC 42001 management system
Audit evidence	Git/change record; test results; approval; deployed policy hash; rollback record

3. Detailed control records — Audit & Evidence

Logs are necessary but insufficient. The control objective is an attestable, version-bound evidence trail that can be independently verified.

A-01 — Logs cannot prove exactly what happened

Summary item	Logs cannot prove what happened
Risk description	A conventional log such as 'INFO: tool called' lacks the agent identity, model/prompt context, policy decision, resource, outcome, and integrity protections needed for reconstruction.
Control objective	Every consequential action produces a structured evidence record sufficient to reconstruct the decision.
Control activities	• Record principal, agent version, target server/tool, action, policy version, decision, timestamp, and outcome. • Capture relevant data-handling and approval metadata without unnecessarily storing sensitive payloads. • Define retention, access, integrity, and deletion rules.
Framework mapping	COBIT DSS01/DSS05; MEA02/MEA03; NIST CSF Detect/Govern; NIST AI RMF Measure/Manage; ISO/IEC 27001 logging/monitoring; DORA logging
Audit evidence	Evidence record; retention configuration; access history; monitoring alert

A-02 — Evidence is mutable or cannot be independently verified

Summary item	Evidence can be altered
Risk description	If audit records can be edited or deleted without detection, an organization may be unable to establish chain of custody during an investigation or regulatory review.
Control objective	Evidence integrity is cryptographically verifiable and tamper-evident.
Control activities	• Hash evidence records and link them into a Merkle-style chain or equivalent integrity structure. • Protect signing keys and evidence stores with appropriate access controls. • Periodically anchor or otherwise externalize integrity proofs where warranted.
Framework mapping	COBIT MEA02/MEA04; DSS05; NIST CSF Protect/Detect; NIST AI RMF Measure; ISO/IEC 27001 integrity; DORA audit/logging
Audit evidence	Record hash; previous-hash pointer; Merkle root/anchor; verification report

A-03 — Audit evidence is disconnected from policy and provenance

Summary item	Evidence lacks provenance/policy linkage
Risk description	A regulator, internal auditor, or incident responder needs more than a timestamp: they need to know which policy, agent composition, and authorization context produced the decision.
Control objective	Evidence links the action to identity, policy, provenance, and outcome.
Control activities	• Link each consequential action to identity ID, policy hash/version, AgBOM/attestation ID, and outcome. • Preserve the relationship even when the agent subsequently changes. • Support evidence export for audit and regulatory workflows.
Framework mapping	COBIT MEA03/MEA04; NIST AI RMF Govern/Measure; ISO/IEC 42001 traceability; EU AI Act documentation/logging relevance; SOX ITGC evidence
Audit evidence	Evidence graph; exported audit package; linked identifiers

A-04 — Monitoring does not detect anomalous agent behavior

Summary item	Anomalies go undetected
Risk description	Even with good logs, an organization can miss unusual tool sequences, excessive delegation, repeated denials, data exfiltration patterns, or rapid changes in behavior.
Control objective	Evidence is operationalized for detection, investigation, and response.
Control activities	• Define behavioral and security signals for the agent mesh. • Alert on policy violations, unusual call velocity, privilege escalation, and anomalous data access. • Feed incidents into response and recovery processes.
Framework mapping	COBIT DSS05.07; DSS02; NIST CSF Detect/Respond/Recover; NIST AI RMF Measure/Manage; ISO/IEC 27001 monitoring
Audit evidence	Detection rules; alerts; incident records; response timestamps

3. Detailed control records — SPDX / AgBOM

Static is dead: build-time SBOMs are snapshots. AgBOM and runtime attestation capture what was actually present when the action occurred.

P-01 — Build-time SBOM is treated as a complete runtime description

Summary item	Static SBOM is stale
Risk description	Traditional SBOMs are useful build-time snapshots, but agents can change prompts, models, retrieval sources, tools, and configuration at runtime. A static inventory can therefore be stale at the moment of action.
Control objective	Runtime composition is represented and attestable when it materially affects behavior or authorization.
Control activities	• Generate/maintain a machine-readable agent bill of materials. • Represent model identity, prompt/version, tool manifest, retrieval sources, dependencies, and relevant runtime state. • Require fresh attestation after material composition changes.
Framework mapping	COBIT BAI10; APO14; MEA02; NIST AI RMF Map/Measure; ISO/IEC 42001 traceability; CRA supply-chain transparency relevance
Audit evidence	AgBOM; runtime attestation; component/version hashes; change events

P-02 — Agent provenance cannot be tied to the action

Summary item	Provenance not tied to action
Risk description	Knowing the agent composition is insufficient if the evidence does not prove which composition was active when a consequential tool call occurred.
Control objective	The evidence record references the exact provenance/attestation state used for the decision.
Control activities	• Assign a stable attestation identifier/hash to the runtime composition. • Include that identifier in the gateway decision and evidence record. • Reject or step up actions when required provenance is missing or invalid.
Framework mapping	COBIT BAI10; MEA02/MEA04; NIST AI RMF Measure/Manage; ISO/IEC 42001 traceability; DORA ICT risk/change
Audit evidence	Attestation ID; provenance hash; gateway decision; evidence linkage

P-03 — Model, prompt, tool, or retrieval changes escape governance

Summary item	Composition changes bypass governance
Risk description	A self-modifying agent may load a new model, prompt, tool, or retrieval source without passing through the same governance controls applied during initial deployment.
Control objective	Material changes to agent composition are detectable and subject to policy.
Control activities	• Define which composition changes are material. • Re-attest and re-evaluate authorization after material changes. • Maintain approved/blocked component and tool inventories where appropriate.
Framework mapping	COBIT BAI06/BAI10; APO13; NIST AI RMF Govern/Map/Manage; ISO/IEC 42001 lifecycle/risk controls; CRA secure lifecycle relevance
Audit evidence	Change event; new attestation; policy decision; component allow/deny result

P-04 — Software and AI supply-chain evidence is incomplete

Summary item	Supply-chain evidence incomplete
Risk description	Third-party models, tools, packages, prompts, and services can introduce unknown licensing, vulnerability, or operational risk. Without machine-readable provenance, review and incident response become manual and inconsistent.
Control objective	The organization maintains a traceable inventory and evidence chain for material agent components.
Control activities	• Use SPDX 3.1 AI Profile and/or compatible AgBOM representations where practical. • Track component identity, versions, sources, licenses, and security-relevant metadata. • Connect inventory findings to gateway policy and remediation workflows.
Framework mapping	COBIT APO10; APO14; BAI09/BAI10; NIST CSF Identify/Protect; NIST AI RMF Govern/Map; ISO/IEC 27001 supplier/asset controls; CRA supply-chain relevance
Audit evidence	SBOM/AgBOM; component register; license/vulnerability findings; remediation tickets

4. Framework crosswalk

This crosswalk shows where the four guardrails naturally fit within common enterprise governance frameworks. It is intended to help a control owner translate the Gateway Registry into an existing GRC language rather than create a parallel compliance program.

Guardrail	Framework	Relevant area	Why it maps
Identity	COBIT 2019	DSS05.04 Managed user identity and logical access; APO13 Managed Security	Identity lifecycle, logical access, security monitoring
Identity	NIST CSF 2.0	Govern / Protect	Governance of identities; access control and authentication
Identity	NIST AI RMF 1.0	Govern / Map / Manage	Roles, accountability, context, human oversight and risk treatment
Identity	ISO/IEC 27001	Access control / identity management	Unique identity, authentication, authorization and lifecycle
Identity	ISO/IEC 42001	AI management system	Accountability, governance and traceability for AI use
Identity	DORA	ICT risk management / access controls	Identity, access restriction and operational resilience
RBAC	COBIT 2019	DSS05.04; DSS06; APO12	Least privilege, business-process controls, risk management
RBAC	NIST CSF 2.0	Protect	Identity management, authentication and access control
RBAC	NIST AI RMF 1.0	Map / Manage	Context, risk tolerance, human oversight and risk treatment
RBAC	ISO/IEC 27001	Access control / change management	Least privilege and controlled changes
RBAC	EU AI Act	Risk management / logging / human oversight	Relevant for high-risk AI controls; applicability depends on system classification
RBAC	DORA	ICT risk / logical access / change management	Dynamic authorization and controlled privileged actions
Audit & Evidence	COBIT 2019	MEA02/MEA03/MEA04; DSS01/DSS05	Internal control, compliance, assurance, logging and monitoring
Audit & Evidence	NIST CSF 2.0	Govern / Detect / Respond	Continuous monitoring, incident analysis and response
Audit & Evidence	NIST AI RMF 1.0	Measure / Manage	Measurement, documentation, monitoring and risk response
Audit & Evidence	ISO/IEC 27001	Logging/monitoring; incident management	Evidence integrity, monitoring and investigation
Audit & Evidence	EU AI Act	Logging / documentation / human oversight	Traceability and evidence for applicable high-risk systems
Audit & Evidence	DORA	Logging / ICT risk / incident management	Event logging and auditability for financial entities
SPDX / AgBOM	COBIT 2019	BAI10 Managed configuration; APO14 Managed Data; APO10 Managed Vendors	Configuration, asset/data and supplier visibility
SPDX / AgBOM	NIST CSF 2.0	Identify / Protect / Govern	Asset inventory, supply-chain risk and governance
SPDX / AgBOM	NIST AI RMF 1.0	Map / Measure	System context, provenance, measurement and traceability
SPDX / AgBOM	ISO/IEC 42001	AI lifecycle / risk management / documented information	AI system inventory, lifecycle and traceability
SPDX / AgBOM	CRA (EU)	Cybersecurity / vulnerability and supply-chain transparency	Software composition and security evidence can support obligations where applicable

Guardrail	Framework	Relevant area	Why it maps
SPDX / AgBOM	DORA	ICT asset/change/supply-chain risk	Configuration and third-party ICT visibility

5. Using the framework in a GRC program

- 1. Define the control owner** — Typically the AI platform / security / technology risk owner, with compliance and business owners for high-impact workflows.
- 2. Register the agent and server** — Create authoritative records for agent identity, ownership, version, MCP server, tools, data classification, and criticality.
- 3. Express policy as code** — Translate risk appetite and business rules into versioned gateway policies. Treat policy like production software.
- 4. Capture runtime provenance** — Create the AgBOM/attestation needed to answer 'what was running when this action occurred?'
- 5. Create the receipt** — For each consequential action, link identity + policy + provenance + action + outcome into an integrity-protected evidence record.
- 6. Map to existing controls** — Attach the record to existing COBIT, ISO, NIST, SOX, DORA, privacy, and AI governance controls instead of creating duplicate controls.
- 7. Test continuously** — Use policy tests, access reviews, attestation validation, evidence verification, anomaly detection, and tabletop incidents.

Suggested control-testing questions

- Can an auditor identify exactly which agent principal initiated a given tool call?
- Can the organization prove what policy version made the allow/deny decision?
- Can it reconstruct the agent's model/prompt/tool/retrieval composition at the time of the action?
- Can a high-impact action be shown to have received the required human or second-factor approval?
- Can the evidence record be independently verified as unmodified?
- Can an administrator demonstrate that policy changes were reviewed, tested, approved and rolled back when necessary?
- Can the organization export a regulator-ready evidence package without reconstructing it manually from disparate logs?

6. Source notes and framework references

KPMG — AI Risk and Controls Matrix (2018). Used as the structural inspiration for summary risk → description → control → framework mapping.

<https://assets.kpmg.com/content/dam/kpmgsites/uk/pdf/2018/09/ai-risk-and-controls-matrix.pdf>

ISACA — COBIT 2019. COBIT provides 40 governance and management objectives and is designed to integrate with other standards, regulations and practices.

<https://www.isaca.org/resources/cobit>

ISACA — COBIT 2019 examples relevant here include DSS05.04 (identity and logical access), APO13 (security), APO12 (risk), BAI10 (configuration), and MEA03/MEA04 (compliance/assurance).

<https://www.isaca.org/resources/news-and-trends/industry-news/2019/defining-target-capability-levels-in-cobit-2019>

NIST — AI Risk Management Framework 1.0: Govern, Map, Measure, Manage.

<https://www.nist.gov/itl/ai-risk-management-framework>

NIST — Cybersecurity Framework 2.0: Govern, Identify, Protect, Detect, Respond, Recover.

<https://www.nist.gov/cyberframework>

ISO — ISO/IEC 42001:2023 — Artificial intelligence management system.

<https://www.iso.org/standard/42001>

European Commission — EU AI Act overview, including risk management, logging, documentation, human oversight and cybersecurity obligations for applicable high-risk systems.

<https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai>

European Union — DORA-related technical standards include requirements for documented logging procedures, identity/access events, change management and ICT operations.

<https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX%3A32024R1774>

Drafting note: Framework mappings are deliberately conservative and should be validated against the organization's licensed/current framework editions, applicable jurisdictions, system classification, contracts, and control library before being used as an audit assertion or regulatory submission.